

Poisoned Pipeline Execution

Adversaries may manipulate continuous integration / continuous development (CI/CD) processes by injecting malicious code into the build process. There are several mechanisms for poisoning pipelines:

- In a **Direct Pipeline Execution** scenario, the threat actor directly modifies the CI configuration file (e.g., `gitlab-ci.yml` in GitLab). They may include a command to exfiltrate credentials leveraged in the build process to a remote server, or to export them as a workflow artifact.^{[1][2]}
- In an **Indirect Pipeline Execution** scenario, the threat actor injects malicious code into files referenced by the CI configuration file. These may include makefiles, scripts, unit tests, and linters.^[2]
- In a **Public Pipeline Execution** scenario, the threat actor does not have direct access to the repository but instead creates a malicious pull request from a fork that triggers a part of the CI/CD pipeline. For example, in GitHub Actions, the `pull_request_target` trigger allows workflows running from forked repositories to access secrets. If this trigger is combined with an explicit pull request checkout and a location for a threat actor to insert malicious code (e.g., an `npm build` command), a threat actor may be able to leak pipeline credentials.^{[1][3]} Similarly, threat actors may craft pull requests with malicious inputs (such as branch names) if the build pipeline treats those inputs as trusted.^{[4][5][6]} Finally, if a pipeline leverages a self-hosted runner, a threat actor may be able to execute arbitrary code on a host inside the organization’s network.^[7]

By poisoning CI/CD pipelines, threat actors may be able to gain access to credentials, laterally move to additional hosts, or input malicious components to be shipped further down the pipeline (i.e., [Supply Chain Compromise](#)).

Procedure Examples

ID	Name	Description
S9042	CanisterWorm	CanisterWorm has leveraged stolen tokens from Trivy users to publish itself across over 46 npm packages. ^{[8][9]}
S9043	Mini Shai-Hulud	Mini Shai-Hulud has utilized Github Actions to propagate through the use of triggered workflows. ^{[10][11][12]}
S9008	Shai-Hulud	Shai-Hulud has also leveraged GitHub actions from stolen accounts in order to create a malicious Github workflow within <code>.github/workflows/discussion.yaml</code> . ^{[13][14][15][16]}
G1056	TeamPCP	TeamPCP has compromised trusted CI/CD pipelines by injecting credential-stealing payloads into legitimate workflows and software packages including open-source security tools Trivy and KICS, and AI gateway LiteLLM. ^{[17][18][19][20][21][8][22][22][10][23][24][11][12][25][26]}

Mitigations

ID	Mitigation	Description
M1054	Software Configuration	Where possible, avoid allowing pipelines to run unreviewed code. Where this is necessary, ensure that these pipelines are executed on isolated nodes without access to secrets. In GitHub, avoid using the <code>pull_request_target</code> trigger if possible, do not treat user-controlled inputs (such as branch names) as trusted,

ID: T1677

Sub-techniques: No sub-techniques

① **Tactic:** [Execution](#)

① **Platforms:** SaaS

Contributors: Arun Seelagan, CISA

Version: 1.0

Created: 22 May 2025

Last Modified: 12 May 2026

[Version](#) [Permalink](#)

Detection Strategy

ID	Name	Analytic ID	Analytic Description
DET0533	Detection Strategy for Poisoned Pipeline Execution via SaaS CI/CD Workflows	AN1473	Detects anomalous CI/CD workflow execution originating from forked repositories, with pull request (PR) metadata or commit messages containing suspicious patterns (e.g., encoded payloads), coupled with the use of insecure pipeline triggers like <code>pull_request_target</code> or excessive API usage of CI/CD secrets. Correlation with unusual artifact generation or secret exfiltration via encoded or external network destination URLs confirms suspicious behavior.

References

1. [Omer Gilm Aviad Hahami, Asi Greenholts, and Yaron Avital. \(2025, March 20\). GitHub Actions Supply Chain Attack: A Targeted Attack on Coinbase Expanded to the Widespread tj-actions/changed-files Incident: Threat Assessment . Retrieved May 22, 2025.](#)

2. [OWASP. \(n.d.\). CICD-SEC-4: Poisoned Pipeline Execution \(PPE\). Retrieved May 22, 2025.](#)

3. [Jaroslav Lobačevski. \(2021, August 3\). Keeping your GitHub Actions and workflows secure Part 1: Preventing pwn requests. Retrieved May 22, 2025.](#)

4. [Wiz Threat Research. \(2024, December 9\). Ultralytics AI Library Hacked via GitHub for Cryptomining. Retrieved May 22, 2025.](#)

5. [Hugo Vincent. \(2024, May 22\). Hijacking GitHub runners to compromise the organization. Retrieved May 22, 2025.](#)

6. [Jaroslav Lobačevski. \(2021, August 4\). Keeping your GitHub Actions and workflows secure Part 2: Untrusted input. Retrieved May 22, 2025.](#)

7. [John Stawinski IV. \(2024, January 11\). Playing with Fire – How We Executed a Critical Supply Chain Attack on PyTorch. Retrieved May 22, 2025.](#)

8. [Eriksen, C. \(2026, March 27\). Popular telnyx package compromised on PyPI by TeamPCP. Retrieved July 16, 2026.](#)

9. [Eriksen, C. \(2026, March 20\). TeamPCP deploys CanisterWorm on NPM following Trivy compromise. Retrieved July 27, 2026.](#)

10. [McCarthy, R., Cohen, A., and Read, B. \(2026, May 12\). Mini Shai-Hulud Strikes Again: TanStack + more npm Packages Compromised. Retrieved July 16, 2026.](#)

11. [Webb, M. \(2026, May 20\). TeamPCP Wave Four: GitHub Breach via Poisoned VS Code Extension, durabletask PyPI Worm, and ~4,000 Internal Repositories Exfiltrated. Retrieved July 16, 2026.](#)

12. [Flashpoint. \(2026, May 28\). The Mini Shai-Hulud Worm and the New Era of CI/CD Exploitation. Retrieved July 16, 2026.](#)

13. [Charlie Eriksen. \(2025, September 16\). S1ngularity/nx attackers strike again. Retrieved April 9, 2026.](#)

14. [Gianpietro Cutolo. \(2025, November 26\). Shai-Hulud 2.0: Aggressive, Automated, and Fast Spreading. Retrieved April 9, 2026.](#)

15. [Justin Moore. \(2025, November 25\). "Shai-Hulud" Worm Compromises npm Ecosystem in Supply Chain Attack \(Updated November 26\). Retrieved April 9, 2026.](#)

16. [Socket Research Team. \(2025, November 24\). Shai Hulud Strikes Again \(v2\). Retrieved April 9, 2026.](#)

17. [McCarthy, R. \(2026, March 20\). Trivy Compromised: Everything You Need to Know about the Latest Supply Chain Attack. Retrieved July 1, 2026.](#)

18. [Aqua Security. \(2026, March 21\). Trivy ecosystem supply chain temporarily compromised. Retrieved July 1, 2026.](#)

19. [Aqua Team. \(2026, April 1\). Update: Ongoing Investigation and Continued Remediation. Retrieved July 1, 2026.](#)

20. [Sysdig Threat Research Team. \(2026, March 23\). TeamPCP expands: Supply chain compromise spreads from Trivy to Checkmarx GitHub Actions. Retrieved July 1, 2026.](#)

21. [McCarthy, R., Haughom, J., Read, B. \(2026, March 23\). KICS GitHub Action Compromised: TeamPCP Strikes Again in Supply Chain Attack. Retrieved July 1, 2026.](#)

22. [Unit 42. \(2026, March 31\). Weaponizing the Protectors: TeamPCP's Multi-Stage Supply Chain Attack on Security Infrastructure. Retrieved July 1, 2026.](#)

23. [Santos, J. and Navato, J.R. \(2026, May 13\). Analyzing TeamPCP's Supply Chain Attacks: Checkmarx KICS and elementary-data in CI/CD Credential Theft. Retrieved July 16, 2026.](#)

24. [Hunt.io. \(2026, May 14\). How TeamPCP's Python Toolkit Survives a C2 Takedown: FIRESCALE, GitHub, and the Victim's Own Account. Retrieved July 16, 2026.](#)

25. [FBI. \(2026, July 2\). Cyber Criminal Group TeamPCP. Retrieved July 7, 2026.](#)

26. [Google Threat Intelligence Group. \(2026, May 11\). GTIG AI Threat Tracker: Adversaries Leverage AI for Vulnerability Exploitation, Augmented Operations, and Initial Access. Retrieved July 7, 2026.](#)